



Lecture 6

Security Controls and Policies

Security Policies

- Technology by itself cannot solve all network security problems. There are some issues that technology cannot stop.
- Examples include the following:
 - Antivirus software won't prevent a user from manually opening an attachment and releasing a virus.
 - A technologically secured network is still very vulnerable if former employees (perhaps some unhappy with the company) still have working passwords or if passwords are simply put on sticky notes on computer monitors.
 - A server is not secure if it is in a room that nearly everyone in the company has access to.
 - A network is not secure if end users are vulnerable to social engineering.

Security Policies

- Policies are used to guide you in how to implement and manage security, including security technology.
- A security policy is a document that defines how an organization will deal with some aspect of security.
- There can be policies regarding end-user behavior, IT response to incidents, or specific issues and incidents.
- Security policies can also be created to deal with regulatory requirements. These types of policies direct members of the organization as to how to comply with certain regulations.
- Policies can also be simply advisory, suggesting to employees how they should handle certain items but not requiring compliance.
 - For example, a policy might advise users that emailing from a smart phone using a Wi-Fi hotspot can be unsecure but not forbid it.



Identifying and Classifying Information and Assets

- Organizations often include classification definitions within a security policy.
- Personnel then label assets appropriately based on the security policy requirements.
- In this context, assets include sensitive data, the hardware used to process it, and the media used to hold it.

Defining Requirements with a Security Policy

- A security policy is a document that defines the security requirements for an organization.
- It identifies assets that need protection and the extent to which security solutions should go to protect them.
- Some organizations create a security policy as a single document, and other organizations create multiple security policies, with each one focused on a separate area.
- Policies are an important element of access control because they help personnel within the organization understand what security requirements are important.
- Senior leadership approves the security policy and, in doing so, provides a broad overview of an organization's security needs.

Defining Data Classifications

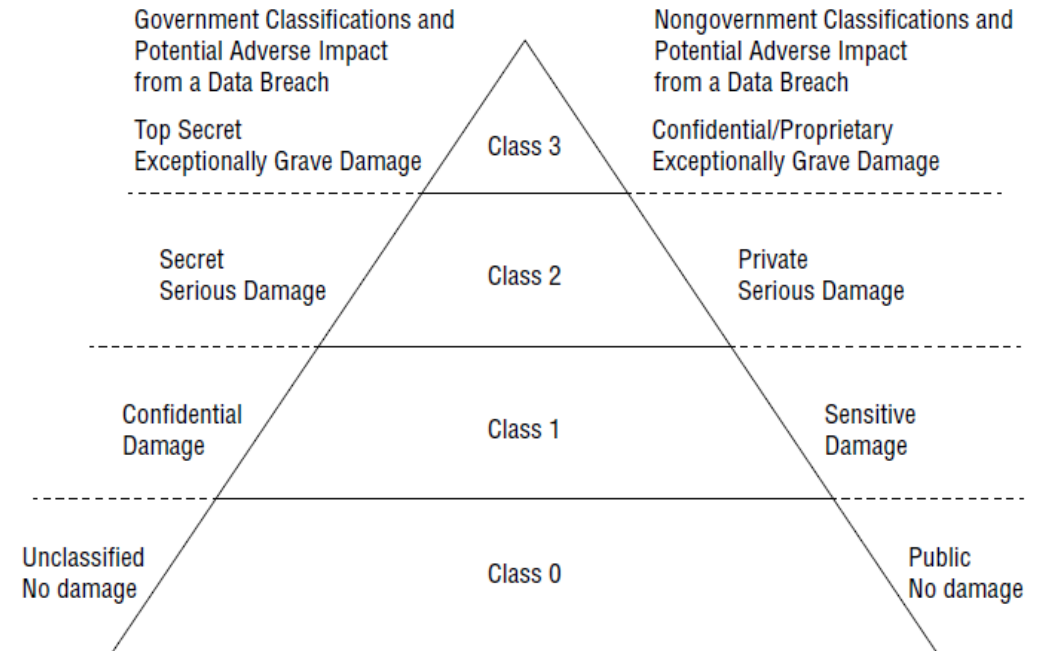
- Organizations typically include data classifications in their security policy or a data policy.
- A data classification identifies the value of the data to the organization and is critical to protect data confidentiality and integrity.
- The policy identifies classification labels used within the organization.
- It also identifies how data owners can determine the proper classification and how personnel should protect data based on its classification.

Defining Data Classifications

- Top Secret - The top secret label is "applied to information, the unauthorized disclosure of which reasonably could be expected to cause exceptionally grave damage to the national security that the original classification authority is able to identify or describe."
- Secret - The secret label is "applied to information, the unauthorized disclosure of which reasonably could be expected to cause serious damage to the national security that the original classification authority is able to identify or describe."
- Confidential - The confidential label is "applied to information, the unauthorized disclosure of which reasonably could be expected to cause damage to the national security that the original classification authority is able to identify or describe."
- Unclassified - Unclassified refers to any data that doesn't meet one of the descriptions for top secret, secret, or confidential data.

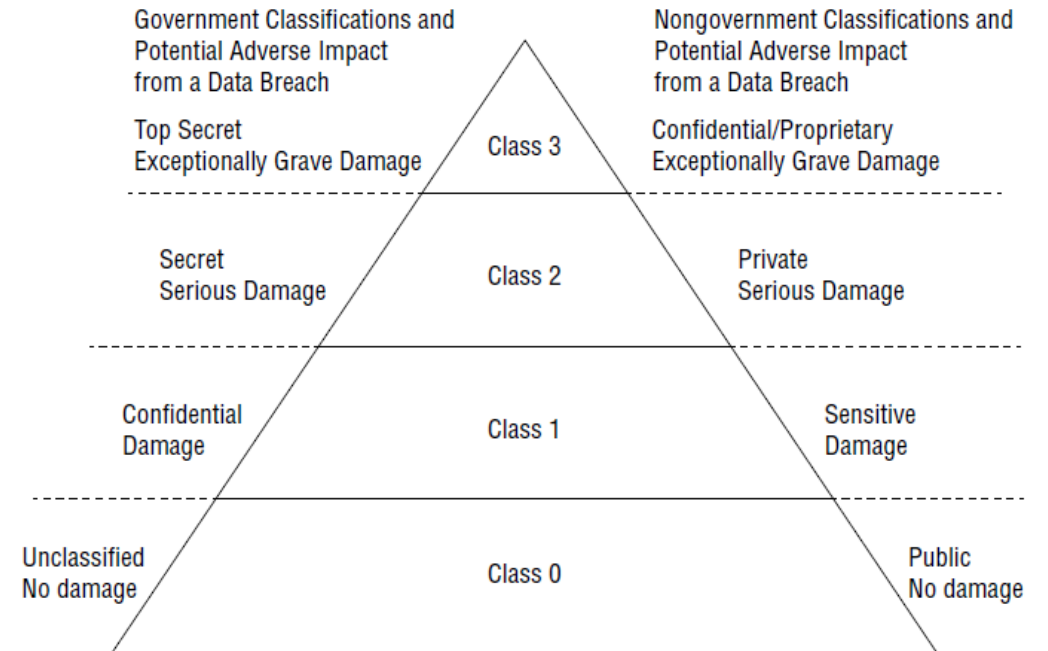
Defining Data Classifications

- Some nongovernmental organizations use labels such as Class 3, Class 2, Class 1, and Class 0.
- Other organizations use more meaningful labels such as confidential (or proprietary), private, sensitive, and public.



Defining Data Classifications

- Some nongovernmental organizations use labels such as Class 3, Class 2, Class 1, and Class 0.
- Other organizations use more meaningful labels such as confidential (or proprietary), private, sensitive, and public.



Understanding Data States

- Data at Rest - Data at rest (sometimes called data on storage) is any data stored on media such as system hard drives, solid-state drives (SSDs), external USB drives, storage area networks (SANs), and backup tapes.
 - Strong symmetric encryption protects data at rest.
- Data in Transit - Data in transit (sometimes called data in motion or being communicated) is any data transmitted over a network.
 - A combination of symmetric and asymmetric encryption protects data in transit.
- Data in Use - Data in use (also known as data being processed) refers to data in memory or temporary storage buffers while an application is using it.

Determining Data Security Controls

- After defining data and asset classifications, you must define the security requirements and identify security controls to implement those requirements.
- Imagine that your organization has decided to use the data labels Confidential/Proprietary, Private, Sensitive, and Public.
- Management then decides on a data security policy dictating the use of specific security controls to protect data in these categories.
- The policy will likely address data stored in files, in databases, on servers such as email servers, on user systems, sent via email, and stored in the cloud.

- Example – Securing email data

Classification	Security requirements for email
Confidential/Proprietary (highest level of protection for any data)	Email and attachments must be encrypted with AES 256. Email and attachments remain encrypted except when viewed. Email can be sent only to recipients within the organization. Email can be opened and viewed only by recipients (forwarded emails cannot be opened). Attachments can be opened and viewed, but not saved. Email content cannot be copied and pasted into other documents. Email cannot be printed.
Private (examples include PII and PHI)	Email and attachments must be encrypted with AES 256. Email and attachments remain encrypted except when viewed. Email can be sent only to recipients within the organization.
Sensitive (lowest level of protection for classified data)	Email and attachments must be encrypted with AES 256.
Public	Email and attachments can be sent in cleartext.

Establishing Information and Asset Handling Requirements

- Data maintenance refers to ongoing efforts to organize and care for data throughout its lifetime.
 - In general, if an organization stores all sensitive data on one server, it is relatively easy to apply all the appropriate controls to this one server.
 - In contrast, if sensitive data is stored throughout an organization on multiple servers and end-user computers and mixed with nonsensitive data, it becomes much harder to protect it.

Establishing Information and Asset Handling Requirements

- Data loss prevention (DLP) systems attempt to detect and block data exfiltration attempts.
 - These systems have the capability of scanning unencrypted data looking for keywords and data patterns.
 - Network-Based DLP - A network-based DLP scans all outgoing data looking for specific data.
 - Administrators place it on the edge of the network to scan all data leaving the organization.
 - If a user sends out a file containing restricted data, the DLP system will detect it and prevent it from leaving the organization.
 - Endpoint-Based DLP An endpoint-based DLP can scan files stored on a system as well as files sent to external devices, such as printers.
 - For example, an organization's endpoint-based DLP can prevent users from copying sensitive data to USB flash drives or sending sensitive data to a printer.

Data Protection Methods

- Digital rights management (DRM) methods attempt to provide copyright protection for copyrighted works.
 - The purpose is to prevent the unauthorized use, modification, and distribution of copyrighted works such as intellectual property.
- A cloud access security broker (CASB) is software placed logically between users and cloud-based resources.
 - It can be on-premises or within the cloud. Anyone who accesses the cloud goes through the CASB software.
 - It monitors all activity and enforces administrator-defined security policies.

Data Protection Methods

- Pseudonymization refers to the process of using pseudonyms to represent other data.
 - Pseudonymization can prevent data from directly identifying an entity, such as a person.
 - As an example, consider a medical record held by a doctor's office. Instead of including personal information such as the patient's name, address, and phone number, it could just refer to the patient as Patient 23456 in the medical record.
- Tokenization is the use of a token, typically a random string of characters, to replace other data.
- Anonymization is the process of removing all relevant data so that it is theoretically impossible to identify the original subject or person.

Controlling Access to Assets

- Controlling access to assets is one of the central themes of security, and you'll find that many different security controls work together to provide access control.
- In addition to personnel, assets can be information, systems, devices, facilities, or applications:
 - Information - An organization's information includes all of its data.
 - Systems - An organization's systems include any IT systems that provide one or more services.
 - Devices - Devices refer to any computing system, including routers, switches, servers, desktop computers, portable laptop computers, tablets, smartphones, and external devices such as printers.
 - Facilities - An organization's facilities include any physical location that it owns or rents.
 - Applications - Applications frequently provide access to an organization's data.

Managing Identification and Authentication

- Identification is the process of a subject claiming, or professing, an identity.
 - A subject must provide an identity to a system to start the authentication, authorization, and accountability processes.
 - Providing an identity might entail typing a username, swiping a smartcard, speaking a phrase, or positioning your face, hand, or finger in front of a camera or in proximity of a scanning device.
 - A core principle with authentication is that all subjects must have unique identities.

Managing Identification and Authentication

- Authentication verifies the subject's identity by comparing one or more factors against a database of valid identities, such as user accounts.
 - The authentication information used to verify identity is private and needs to be protected. As an example, passwords are rarely stored in cleartext within a database.
 - Instead, authentication systems store hashes of passwords in the authentication database.
- Identification and authentication occur together as a single two-step process.
 - Providing an identity is the first step, and providing the authentication information is the second step.
 - Without both, a subject cannot gain access to a system.

Comparing Subjects and Objects

- Access control addresses more than just controlling which users can access which files or services.
- Access is the transfer of information from an object to a subject, which makes it important to understand the definition of both subject and object.
 - Subject - A subject is an active entity that accesses a passive object to receive information from, or data about, an object.
 - Subjects can be users, programs, processes, services, computers, or anything else that can access a resource
 - Object - An object is a passive entity that provides information to active subjects.
 - Examples of objects are files, databases, computers, programs, processes, services, printers, and storage media.

Authorization and Accountability

- Two additional security elements in an access control system are authorization and accountability:
 - Authorization - Subjects are granted access to objects based on proven identities.
 - For example, administrators grant users access to files based on the user's proven identity.
 - Accountability - Users and other subjects can be held accountable for their actions when auditing is implemented.
 - Auditing tracks subjects and records when they access objects, creating an audit trail in one or more audit logs.

Authentication Factors Overview

- There are three primary authentication factors:
 - Something You Know The something you know factor of authentication includes memorized secrets such as a password, personal identification number (PIN), or passphrase.
 - Something You Have - The something you have factor of authentication includes physical devices that a user possesses and can help them provide authentication.
 - Examples include a smartcard, hardware token, memory card, or Universal Serial Bus (USB) drive.
 - Something You Are - The something you are factor of authentication uses physical characteristics of a person and is based on biometrics.
 - Examples in the something you are category include fingerprints, face scans, retina patterns, iris patterns, and palm scans.

Password Policy Components

- Organizations often include a written password policy in the overall security policy.
- The following list includes some common password policy settings:
 - Maximum Age - This setting requires users to change their password periodically, such as every 45 days. Some documents refer to this as password expiration.
 - Password Complexity - Password complexity refers to how many character types it includes. The different character types are lowercase letters, uppercase letters, numbers, and special characters.
 - Password Length - The length is the number of characters in the password, such as at least eight characters long.
 - Minimum Age - This setting prevents users from changing their password again until a certain time has passed.
 - Password History - A password history remembers a certain number of previous passwords and prevents users from reusing passwords.

Implementing Identity Management

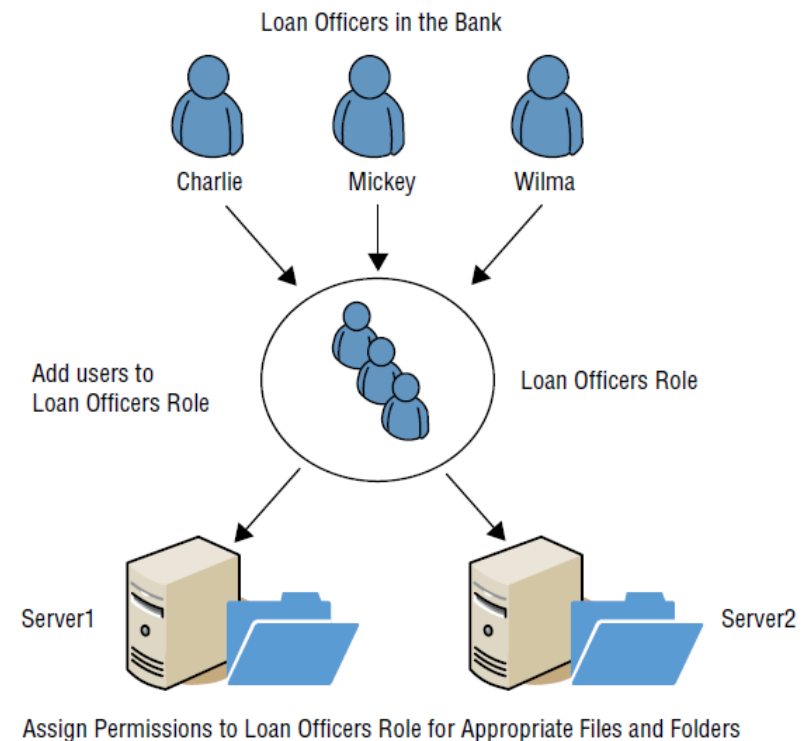
- Identity management (IdM) implementation techniques generally fall into two categories:
 - Centralized access control implies that a single entity within a system performs all authorization verification.
 - A small team or individual can manage centralized access control.
 - Administrative overhead is lower because all changes are made in a single location, and a single change affects the entire system.
 - However, a vulnerability is that centralized access control potentially creates a single point of failure.
 - Decentralized access control (also known as distributed access control) implies that various entities located throughout a system perform authorization verification.
 - Decentralized access control often requires several teams or multiple individuals.
 - Administrative overhead is higher because changes must be implemented across numerous locations.
 - Maintaining consistency across a system becomes more difficult as the number of access control points increases.

Introducing Access Control Models

- Discretionary Access Control
 - A key characteristic of the Discretionary Access Control (DAC) model is that every object has an owner and the owner can grant or deny access to any other subjects.
 - For example, if you create a file, you are the owner and can grant permissions to any other user to access the file.
 - The New Technology File System (NTFS), used on Microsoft Windows operating systems, uses the DAC model.

Introducing Access Control Models

- Role-Based Access Control
 - A key characteristic of the Role-Based Access Control (RBAC) model is the use of roles or groups. Instead of assigning permissions directly to users, user accounts are placed in roles and administrators assign privileges to the roles.
 - These roles are typically identified by job functions.
 - Microsoft Windows operating systems implement this model with the use of groups.



Introducing Access Control Models

- Rule-Based Access Control
 - A key characteristic of the rule-based access control model is that it applies global rules to all subjects.
 - As an example, a firewall uses rules that allow or block traffic to all users equally.
 - Rules within the rule-based access control model are sometimes referred to as restrictions or filters.
- Attribute-Based Access Control
 - A key characteristic of the Attribute-Based Access Control (ABAC) model is its use of rules that can include multiple attributes.
 - This allows it to be much more flexible than a rule-based access control model that applies the rules to all subjects equally.
 - Many software-defined networks (SDNs) use the ABAC model.

Introducing Access Control Models

- Mandatory Access Control
 - A key characteristic of the Mandatory Access Control (MAC) model is the use of labels applied to both subjects and objects.
 - For example, if a user has a label of top secret, the user can be granted access to a top-secret document. In this example, both the subject and the object have matching labels.

Lentil	Foil	Crimson	Matterhorn	Confidential
Domino	Primrose	Sleuth	Potluck	Private
				Sensitive
				Public

Introducing Access Control Models

- Risk-Based Access Control
 - A risk-based access control model grants access after evaluating risk.
 - It evaluates the environment and the situation and makes risk-based decisions using policies embedded within software code.
 - It uses machine learning to make predictive conclusions about current activity based on past activity.

Security Procedures

- Procedures are the final element of the formalized security policy structure.
 - A procedure or standard operating procedure (SOP) is a detailed, step-by-step how-to document that describes the exact actions necessary to implement a specific security mechanism, control, or solution.
 - A procedure could discuss the entire system deployment operation or focus on a single product or aspect.
 - They must be updated as the hardware and software of a system evolve.
 - The purpose of a procedure is to ensure the integrity of business processes through standardization and consistency of results.

Personnel Security Policies and Procedures

- Humans are often considered the weakest element in any security solution.
- No matter what physical or logical controls are deployed, humans can discover ways to avoid them, circumvent or subvert them, or disable them.
- Thus, it is important to take into account the humanity of your users when designing and deploying security solutions for your environment.
- To understand and apply security governance, you must address the weakest link in your security chain—namely, people.

Onboarding: Employment Agreements and Policies

- Onboarding is the process of adding new employees to the organization, having them review and sign employment agreements and policies, be introduced to managers and coworkers, and be trained in employee operations and logistics.
 - A new employee will be provided a computer/network user account.
 - This is accomplished through the identity and access management (IAM) system of an organization, which will provision the account and assign necessary privileges and access.
 - The onboarding process is also used when an employee's role or position changes or when that person is awarded additional levels of privilege or access.
- To maintain security, access should be assigned according to the principle of least privilege.
 - The principle of least privilege states that users should be granted the minimum amount of access necessary for them to complete their required work tasks or job responsibilities.
 - True application of this principle requires low-level granular control over all resources and functions.

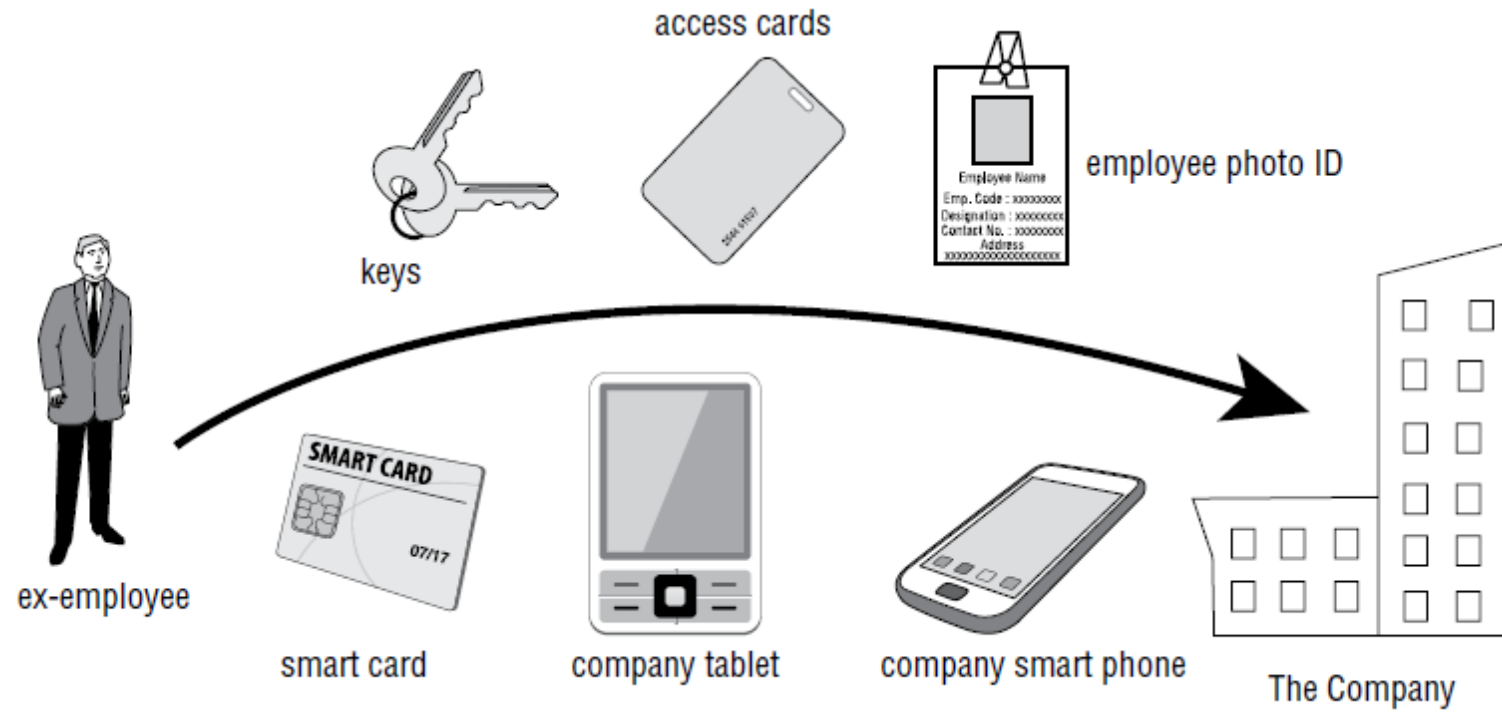
Employee Oversight

- Throughout the employment lifetime of personnel, managers should regularly review or audit the job descriptions, work tasks, privileges, and responsibilities for every staff member.
 - It is common for work tasks and privileges to drift over time.
 - Drifting job responsibilities or privilege creep can also result in security violations.
 - Excess privileges held by a worker represent increased risk to the organization.
 - Reviewing and then adjusting user capabilities to realign with the principle of least privilege is a risk reduction strategy.

Offboarding, Transfers, and Termination Processes

- Offboarding is the removal of an employee's identity from the IAM system once that person has left the organization.
- Offboarding can also be an element used when an employee transfers into a new job position at the same organization, especially when they are shifting between departments, facilities, or geographic locations.
- When a full offboarding is going to occur, this can include disabling and/or deleting the user account, revoking certificates, canceling access codes, and terminating other specifically granted privileges.
- It is common to disable accounts of prior employees in order to retain the identity for auditing purposes for a few months. After the allotted time, if no incidents are discovered in regard to the ex-employee's account, then it can be deleted from the IAM completely.
- If the account is deleted prematurely, any logged events that are of a security concern no longer point to an actual account and thus can make tracking down further evidence of violations more complicated.

Offboarding, Transfers, and Termination Processes



Change Management

- The nature of information technology is change. Not only do end users come and go, but requirements change frequently.
- Business units request access to different resources, server administrators upgrade software and hardware, application developers install new software, and web developers change the website.
- Change is occurring all the time. Therefore, it is important to have a change control process.
- This process not only makes the change run smoothly, but it also allows the IT security personnel to examine the change for any potential security problems before it is implemented.

Change Management

- A change control request should go through the following steps:
 1. An appropriate manager within the business unit signs the request, signifying approval of the request.
 2. The appropriate IT unit (database administration, network admin, email admin, cloud administration) verifies that the request is one it can fulfill technologically, fits within budget constraints, and does not violate IT policies.
 3. The IT security unit verifies that this change will not cause security problems. This is becoming more and more critical in modern times.
 4. The appropriate IT unit formulates a plan to implement the change and a plan to roll back the change in the event of some failure.
 5. The date and time for the change is scheduled, and all relevant parties are notified.

Change Management

- Change management activities are frequently managed through a change control board (CCB) process, sometimes also called a change approval board (CAB) process.
- The basic process can be summarized as follows:
 - Initiate the process with an RFC (request for comments or request for change) document
 - Send the RFC for approval
 - Set the priority of the process
 - Assign the process to whomever makes the change
 - Document decisions
 - Have the CAB evaluate changes
 - Schedule the RFC
 - Have the change owner and requester verify successful implementation of the change
 - Review the RFC

Development Policies

- Many IT departments include programmers and web developers.
- Unfortunately, many security policies do not address secure programming.
- No matter how good your firewalls, proxy server, virus scanning, and policies are, if your developers create code that is flawed, you will have security breaches.
- We can consider a brief checklist for defining secure development policies.

Development Policies

- Secure programming:
 - All code, especially code written by outside parties (contractors, consultants, and so on) must be checked for backdoors/Trojan horses.
 - All buffers must have error handling that prevents buffer overruns.
 - All communication (such as using TCP sockets to send messages) must adhere to your organization's secure communications guidelines.
 - Any code that opens any port or performs any sort of communication needs to be thoroughly documented, and the IT security unit must be apprised of the code, what it will do, and how it will be used.
 - All input should be filtered for items that might facilitate an attack, such as an SQL injection attack.
 - Every vendor should supply you with a signed document verifying that there are no security flaws in its code.